Énumérons d'abord les 14 cathégorie de scripts pouvant être utilisés :

- auth détermination des identifiants d'authentification
- broadcast scripts utilisé pour la découverte d'hotes par diffusion
- brute scripts qui tentent de se connecter à un service par bruteforce
- default scripts par défault utilisés avec l'option -sC
- discovery evaluation des services accessibles
- dos scripts utilisé pour l'evaluation des vulnérabilités des (endommagent les serv
- exploit cet cathégorie tentes d'exploiter les vulnerabilités connues pour le port
- external utilise des services externes (Ex Wois-IP).
- fuzzer scripts pour identifier les vulnérabilités et gestions inattendues des packets en envoyant différents champs ce qui peu prendre beaucoup de temps.
- intrusive scripts intrusif qui peuvent affecter négativement le system cible
- malware essai de detecter la présence d'un malware sur le system cible
- safe scripts defensifs n'effectuent pas d'acès intrusifs ou destructeurs
- version extention pour la détection des services
- vuln identification des vulnérabilités spécifiques

Scripts par défault :

~$ sudo nmap <target> -sC

Cathégorie de scripts spécifiques :

~$ sudo nmap <target> --script <catégory>

Scripts définis :

~$ sudo nmap <target> --script <scriptname1>,<scriptname2>,<...

Il existe aussi une option de scan dite agressive avec l'option -A ce scan regroupe la détection des services de -sV celle de l'OS avec -O le traceroute avec --traceroute ainsi que les scripts NSE par défault soit l'option -sC.

Les Performances:

Les performances de scan jouent un role important lorsque nous devons scanner un réseau étendu ou lorsque nous avons à faire avec une faible bande passante réseaux. Nous pouvons utiliser diverses options pour indiquer à nmap à quelle vitesse (-T <0-5>), avec quelle fréquence (--min-parallelism <numbers>) quels timeouts (--max-rtt-timeout <timeinms>) les paquets de tests doivent avoir, combien de paquets doivent être employés simultanements (--min-rate <number>) et avec quels nombres de réessais (--max-retries <number>) pour les ports scannés, les cibles doivent être scannées.

Evasion de par-feu et d'IDS/IPS :

Commençon par quelques définitions:

Par-feu (firewall) c'est une mesure de sécurité contre les connexions non autorisées provenant des réseaux externes. Chaque par-feu est basé sur des composants logiciels et/ou materiels qui surveille le trafic réseau lorsqu'il traverse le par-feu et décide de la manière de traiter les connexions en fonction des règles établies. Il est conçu pour empêcher les connexions indesirables et potentiellement dangereuses.

IDS/IPS: (Intrusion Detection System) et (Intrusion Prevention System) sont des composants logiciels Les premier analysent le reseau et signalent toute attaques detectés. Les seconds prennent des mesures defensives spécifique a chaque attaque potentielle detecté.

- La methode de scan TCP ACK (-sA) est beaucoup plus difficile à filtrer par les par-feu IDS et IPS que les scans SYN(-sS) ou connect (-sT) classiques, car ils n'envoyent qu'un packet TCP avec l'unique drapeau ACK en revanche il ne peu pas déterminer "explicitement" si un port est open